R.M.K
GROUP OF ENGINEERING INSTITUTIONS

R.M.K
GROUP OF
INSTITUTIONS

R.M.K
GROUP OF INSTITUTIONS







R.M.K
GROUP OF
INSTITUTIONS

R.M.K GROUP OF INSTITUTIONS

Please read this disclaimer before proceeding:

This document is confidential and intended solely for the educational purpose of RMK Group of Educational Institutions. If you have received this document through email in error, please notify the system manager. This document contains proprietary information and is intended only to the respective group / learning community as intended. If you are not the addressee you should not disseminate, distribute or copy through e-mail. Please notify the sender immediately by e-mail if you have received this document by mistake and delete this document from your system. If you are not the intended recipient you are notified that disclosing, copying, distributing or taking any action in reliance on the contents of this information is strictly prohibited.

22CS912

CLOUD SECURITY FOUNDATIONS

Department : **CSE**

Batch/Year : **2023-2027 / IV Year**

Prepared /Updated by:

Ms. A. Jasmine Gilda, Associate Professor / RMKEC – CSE

Dr. K. Roslin Dayana, Associate Professor/RMDEC – CSE

Dr. A. Nazreen Banu, Associate Professor/ RMDEC - CSE

Mr. V. M. Jemin, Associate Professor/RMKCET – CSE

Date : 09.05.2026

R.M.K GROUP OF INSTITUTIONS

1. CONTENTS

S. No.	Contents
1	Contents
2	Course Objectives
3	Pre-Requisites
4	Syllabus
5	Course outcomes
6	CO- PO/PSO Mapping
7	Lecture Plan
8	Activity based learning
9	Lecture Notes
10	Assignments
11	Part A Questions & Answers
12	Part B Questions
13	Online Certifications
14	Real Time Applications
15	Self-Learning / Enrichment Topics
16	Assessment Schedule
17	Text Books & Reference Books
18	Mini Project / Activity

R.M.K GROUP OF INSTITUTIONS

2. COURSE OBJECTIVES

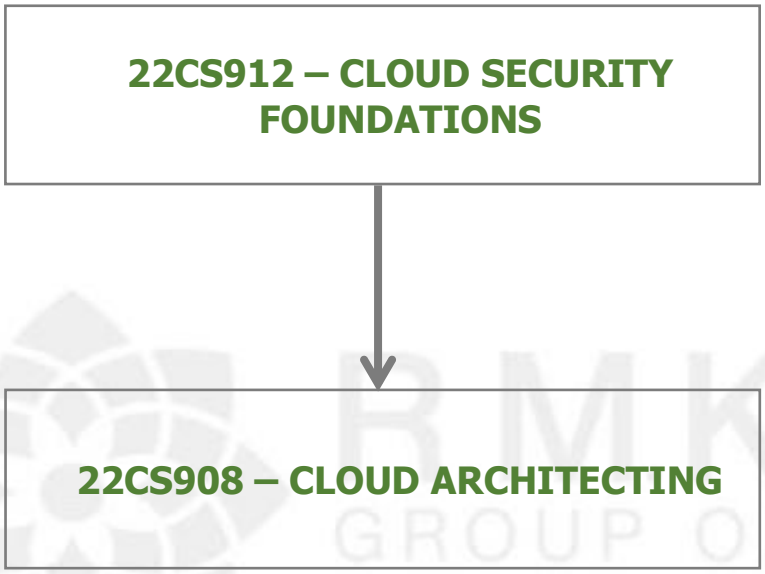
The Course will enable learners to:

- Learn the basics of cloud security, including the shared responsibility model and identity management.
- Set up a secure cloud infrastructure with features like virtual private clouds and security groups.
- Safeguard application data at rest and in transit using encryption and Amazon S3 protection features.
- Learn to capture and analyze log data using AWS services like CloudTrail and CloudWatch.
- Develop skills for identifying and managing security incidents in the cloud, adhering to best practices.

R.M.K GROUP OF INSTITUTIONS

3. PRE REQUISITES

- **Pre-requisite Chart**



4. SYLLABUS

22CS912	CLOUD SECURITY FOUNDATIONS	L	T	P	C
		3	0	0	3

UNIT I SECURITY IN CLOUD **9**

Introduction to Security, Security in the Cloud, Security design principles, Shared responsibility model, Activity: Shared Responsibility Model, Identity and Access Management (IAM) fundamentals, Authenticating and Authorizing with IAM, Examples of authorizing with IAM, Additional authentication and access management services, Using Organizations.

UNIT II SECURING INFRASTRUCTURE **9**

Structure of a three-tier web application, virtual private cloud (VPC), Setting up public and private subnets and internet protocols, Security groups, Network access control lists (ACLs), Load balancers, Protecting compute resources.

UNIT III PROTECTING APPLICATION DATA **9**

Basics on Data Protection, Protect data at rest, Amazon S3 protection features, Protection through encryption, Protect data in transit, protect data in Amazon S3, additional data protection services.

UNIT IV LOGGING AND MONITORING **9**

Importance of logging and monitoring, Capture and collect, Reading a Log File, AWS services with built-in logs, Monitor and report, CloudTrail and Amazon CloudWatch, methods for logging and monitoring, additional AWS services for logging and monitoring, AWS Security Hub.

UNIT V RESPONDING AND MANAGING AN INCIDENT **9**

Identifying an incident, Services that support the discovery and recognition phase, AWS Config and AWS Lambda, Services that support the resolution and recovery phase, Best practices for handling an incident.

TOTAL: 45 PERIODS

5. COURSE OUTCOME

At the end of this course, the students will be able to:

CO1: Learn essential cloud security principles and identity management fundamentals.

CO2: Design and implement secure cloud infrastructure components for effective resource protection.

CO3: Explore methods for securing application data stored in the cloud, including encryption techniques and data protection features.

CO4: Gain proficiency in implementing logging and monitoring practices to detect and respond to security events efficiently in cloud environments.

CO5: Acquire skills to identify and manage security incidents in the cloud, utilizing appropriate tools and techniques for incident detection, analysis, and resolution.

CO6: Proficiently ensure the protection of cloud environments by applying strong security measures across all aspects, ensuring resilience and compliance.

R.M.K GROUP OF INSTITUTIONS

6. CO - PO / PSO MAPPING

CO	HKL	PROGRAM OUTCOMES												PSO		
		PO-1	PO-2	PO-3	PO-4	PO-5	PO-6	PO-7	PO-8	PO-9	PO-10	PO-11	PO-12	PSO-1	PSO-2	PSO-3
CO1	K3	3	2	-	-	2	-	-	1	2	-	-	1	2	2	2
CO2	K3	3	3	3	-	3	-	-	1	-	-	-	2	3	3	2
CO3	K3	3	3	2	-	2	-	-	2	-	-	-	2	3	2	2
CO4	K3	2	3	2	-	2	-	-	1	-	1	-	2	2	2	2
CO5	K3	2	3	2	-	2	-	-	2	1	1	-	3	2	2	2
C06	K3	2	3	2	-	2	-	-	2	2	1	-	3	2	2	2

Correlation Level:

1. Slight (Low)

2. Moderate (Medium)

3. Substantial (High)

If there is no correlation, put "-".

R.M.K GROUP OF INSTITUTIONS

7. LECTURE PLAN

S. No.	Topic	Numberof Periods	CO	Taxonomy Level	Mode of Delivery
1	Introduction to Security	1	CO1	K1	PPT
2	Security in the Cloud	1	CO1	K2	PPT
3	Security design principles	1	CO1	K2	PPT
4	Shared responsibility model	1	CO1	K2	PPT
5	Activity: Shared Responsibility Model	1	CO1	K3	PPT
6	Identity and Access Management (IAM) fundamentals	1	CO1	K2	PPT/Demo
7	Authenticating and Authorizing with IAM	1	CO1	K2	PPT/ Demo
8	Examples of authorizing with IAM	1	CO1	K3	Demo
9	Additional authentication and access management services, Using Organizations	1	CO1	K2	PPT

R.M.K GROUP OF INSTITUTIONS

8. ACTIVITY BASED LEARNING

IAM Role Play:

- **Activity:** Assume different organizational roles such as Administrator, Developer, Security Auditor, and End User. Discuss and justify the permissions required for each role and identify potential security risks arising from excessive privileges.
- **Outcome:** Students will understand the importance of identity and access management and the principle of least privilege.

Secure Cloud Organization Design - Discussion:

- **Activity:** Students design a cloud account structure for a fictional company, including departments, users, groups, and access policies. Teams present and defend their designs.
- **Outcome:** Students will learn to organize and secure cloud resources using governance and access control principles.

R.M.K GROUP OF INSTITUTIONS

9. UNIT I - LECTURE NOTES

1. INTRODUCTION TO SECURITY

Cloud security is the collection of technologies, policies, and controls used to protect data, applications, and infrastructure hosted online from cyber threats. It ensures that cloud resources remain private, accurate, and accessible only to authorized users.

Why Cloud Security is important?

Transitioning from traditional infrastructure to the cloud alters the threat landscape. Cloud security is critical because:

- The Erasure of the Physical Perimeter: Traditional security relied on a "castle-and-moat" approach (physical walls and data center firewalls). In the cloud, infrastructure is software-defined and accessed via the internet. Identity and code become the new perimeter.
- Automated and Rapid Threats: The cloud operates at immense speed. Malicious bots constantly scan the public internet for misconfigured cloud resources. A single configuration oversight can be discovered and exploited by attackers within minutes.
- Centralization of Value: Cloud environments house an organization's most critical digital assets—intellectual property, financial data, and user records—making them high-value targets for cybercriminals.

Benefits of Cloud Security:

When built correctly, leveraging an established cloud environment provides distinct security advantages over traditional on-premises data centers:

- Keep Your Data Safe: Leading cloud providers build their physical infrastructure with military-grade, multi-layered security protections. By deploying in these environments, your data inherits robust physical and network safeguards designed to protect privacy at the lowest layers of the stack.
- Meet Compliance Requirements: Cloud infrastructure is continuously audited to meet dozens of global, regional, and industry-specific compliance standards (such as ISO, SOC, and regional data privacy laws). Operating in the cloud means major portions of an organization's regulatory compliance roadmap are inherited and already completed.

- Save Money: Managing a private, highly secure physical facility requires massive capital expenditure. Utilizing cloud infrastructure allows organizations to leverage enterprise-grade security tools and physical protection at a fraction of the cost, eliminating the overhead of building and maintaining custom facilities.
- Scale Quickly: As an organization's data footprint and infrastructure grow, its security posture scales dynamically alongside it. Cloud security architectures are designed to automatically apply protections to new resources as they are deployed, ensuring consistent defense regardless of business size or workload volume.

Seven Areas of Cloud Security

1. Security Foundations
    - Establishes the basic security practices, policies, governance, and compliance requirements needed to secure cloud environments.
2. Identity and Access Management (IAM)
    - Controls who can access cloud resources and what actions they are allowed to perform through authentication and authorization mechanisms.
3. Detection
    - Involves monitoring systems and activities to identify security threats, suspicious behavior, and potential vulnerabilities.
4. Infrastructure Protection
    - Protects cloud infrastructure, networks, servers, and virtual machines from unauthorized access and cyberattacks.
5. Data Protection
    - Safeguards data from unauthorized access, modification, or loss through encryption, backup, and access control mechanisms.
6. Incident Response
    - Provides processes and tools to detect, contain, investigate, and recover from security incidents effectively.
7. Application Security
    - Ensures that applications are designed, developed, and maintained securely to prevent vulnerabilities and attacks.

R.M.K GROUP OF INSTITUTIONS

2. SECURITY IN THE CLOUD

2.1 Benefits of the cloud:

1. **Pay Only for What You Use**
    - Instead of investing heavily in servers and data centers upfront, organizations pay only for the resources they actually use.
2. **Lower Costs Through Economies of Scale**
    - Cloud providers like AWS serve millions of customers, allowing them to offer computing resources at lower costs than most organizations can achieve on their own.
3. **Flexible Capacity**
    - Organizations can easily increase or decrease resources based on demand, avoiding both over-provisioning and resource shortages.
4. **Faster Deployment and Greater Agility**
    - New IT resources can be provisioned within minutes, enabling quicker development, testing, and deployment of applications.
5. **Reduced Infrastructure Management**
    - Organizations do not need to spend time and money maintaining physical data centers, allowing them to focus on their core business goals.
6. **Global Reach**
    - Applications can be deployed across multiple regions worldwide quickly, providing better performance and lower latency for users around the globe.

2.2 The CIA Triad of Information Security:

Security is the process of protecting information and systems from unauthorized access, misuse, modification, or destruction. The foundation of information security is the CIA Triad, which consists of three key principles: Confidentiality, Integrity, and Availability.

- **Confidentiality** ensures that information is accessible only to authorized users and remains protected from unauthorized access or disclosure.
- **Integrity** ensures that data remains accurate, consistent, and trustworthy. It protects information from unauthorized changes and helps verify that data comes from a legitimate source.

R.M.K GROUP OF INSTITUTIONS

- **Availability** ensures that information and systems are accessible to authorized users whenever needed. A system that is unavailable can disrupt business operations and reduce productivity.

Maintaining these three principles is essential for protecting information in both traditional IT environments and cloud computing platforms. Together, they form the foundation of a strong security strategy.

2.3 Objectives of AWS Cloud Security:

Security in the cloud is similar to security in traditional data centers, but without the need to manage physical infrastructure such as servers and storage devices. AWS provides software-based security services and tools to help organizations protect their resources, monitor activities, and manage access effectively.

The key objectives of AWS Cloud Security are:

1. Controllability

Controllability refers to managing who can access AWS resources and what actions they can perform.

- AWS provides secure access management through IAM (Identity and Access Management).
- IAM enables authentication (who can access) and authorization (what they can access).
- Different permissions can be assigned to different users, groups, and roles.
- AWS Security Token Service (STS) provides temporary security credentials for secure access.
- AWS CloudHSM helps organizations securely generate, store, and manage encryption keys.

Benefits:

- Fine-grained access control
- Secure user authentication
- Protection of encryption keys

2. Auditability

Auditability helps organizations track and review activities performed within their AWS environment.

R.M.K GROUP OF INSTITUTIONS

- AWS supports security audits and compliance requirements.
- AWS CloudTrail records user activities and API calls.
- Organizations can identify:
    - Who performed an action
    - What action was performed
    - When it occurred
    - The source IP address of the activity

Benefits:

- Compliance support
- Activity tracking
- Security investigations and reporting

3. Visibility

Visibility provides insight into AWS resources, configurations, and user activities.

- Organizations can maintain an accurate inventory of their cloud resources.
- AWS Config helps discover, monitor, and track resource configurations.
- Configuration changes can be reviewed at any point in time.

Benefits:

- Resource monitoring
- Change tracking
- Security analysis and troubleshooting

4. Agility and Automation

AWS enables organizations to respond quickly to changing security and business requirements.

- Resources can scale automatically to handle increased workloads or security incidents.
- Applications can be deployed across multiple Regions and Availability Zones for higher availability.
- Automation tools such as AWS CloudFormation help deploy secure and consistent environments.
- Security operations can be automated using AWS APIs and services.

Benefits:

- Faster deployment

R.M.K GROUP OF INSTITUTIONS

- Improved availability and resilience
- Reduced manual effort
- Consistent and secure infrastructure

3. SECURITY DESIGN PRINCIPLES

AWS follows a set of security design principles that help organizations build secure, reliable, and scalable cloud environments. These principles form the foundation of cloud security and guide the implementation of security controls across AWS services.

1. Implement a Strong Identity Foundation

Apply the principle of least privilege, granting users only the permissions required to perform their tasks. Enforce separation of duties and centralize identity management. Use IAM roles, federation, and temporary credentials instead of long-term access keys to reduce security risks.

2. Maintain Traceability

Monitor, log, and audit all activities within the cloud environment. Services such as AWS CloudTrail, Amazon CloudWatch, and AWS Config help organizations track user actions, detect suspicious activities, and support compliance and forensic investigations.

3. Apply Security at All Layers

Adopt a defense-in-depth approach by implementing security controls across every layer of the infrastructure, including networks, compute resources, operating systems, applications, and data. Multiple layers of protection reduce the likelihood of successful attacks.

4. Automate Security Best Practices

Use automation to improve security, consistency, and scalability. AWS services and APIs enable automated deployment, monitoring, compliance checks, and incident response, reducing human error and accelerating security operations.

5. Protect Data in Transit and at Rest

Safeguard sensitive data through encryption, access controls, and data classification. Protect data while it is stored (data at rest) and while it is being transmitted (data in transit) using technologies such as encryption, VPNs, and secure communication protocols.

6. Minimize the Attack Surface

Reduce opportunities for attackers by removing unnecessary services, restricting network

R.M.K GROUP OF INSTITUTIONS

access, and limiting permissions. Configure security groups, network ACLs, and hardened system configurations to reduce exposure to potential threats.

7. Keep People Away from Data

Minimize direct human access to sensitive data by using automated processes, role-based access controls, and secure tools. This reduces the risk of accidental exposure, unauthorized modifications, and human error.

8. Prepare for Security Events

Develop and regularly test incident response plans to ensure effective handling of security incidents. Maintain detailed logs, automate response actions where possible, and establish procedures for detection, investigation, containment, and recovery.

4. SHARED RESPONSIBILITY MODEL

Security and compliance in AWS follow a Shared Responsibility Model, where security responsibilities are divided between AWS and the customer. This model reduces the customer's operational burden while providing flexibility and control over cloud resources.

Security of the Cloud – AWS Responsibility

AWS is responsible for protecting the infrastructure that runs all AWS services. This includes:

- Physical data centers and facilities
- Hardware and storage devices
- Networking infrastructure
- Host operating systems
- Virtualization and hypervisor layer
- Global AWS infrastructure, including Regions, Availability Zones, and Edge Locations

AWS manages, operates, and secures the underlying cloud infrastructure to ensure a secure and reliable cloud environment.

Security in the Cloud – Customer Responsibility

Customers are responsible for securing the resources and applications they deploy on AWS. The level of responsibility depends on the AWS services being used.

Customer responsibilities include:

- Managing operating systems and applying security patches (for services such as

Amazon EC2)

- Securing applications and databases
- Configuring security groups, firewalls, and network settings
- Managing user identities, permissions, and access controls
- Protecting and classifying data
- Implementing encryption and key management
- Monitoring and maintaining compliance requirements

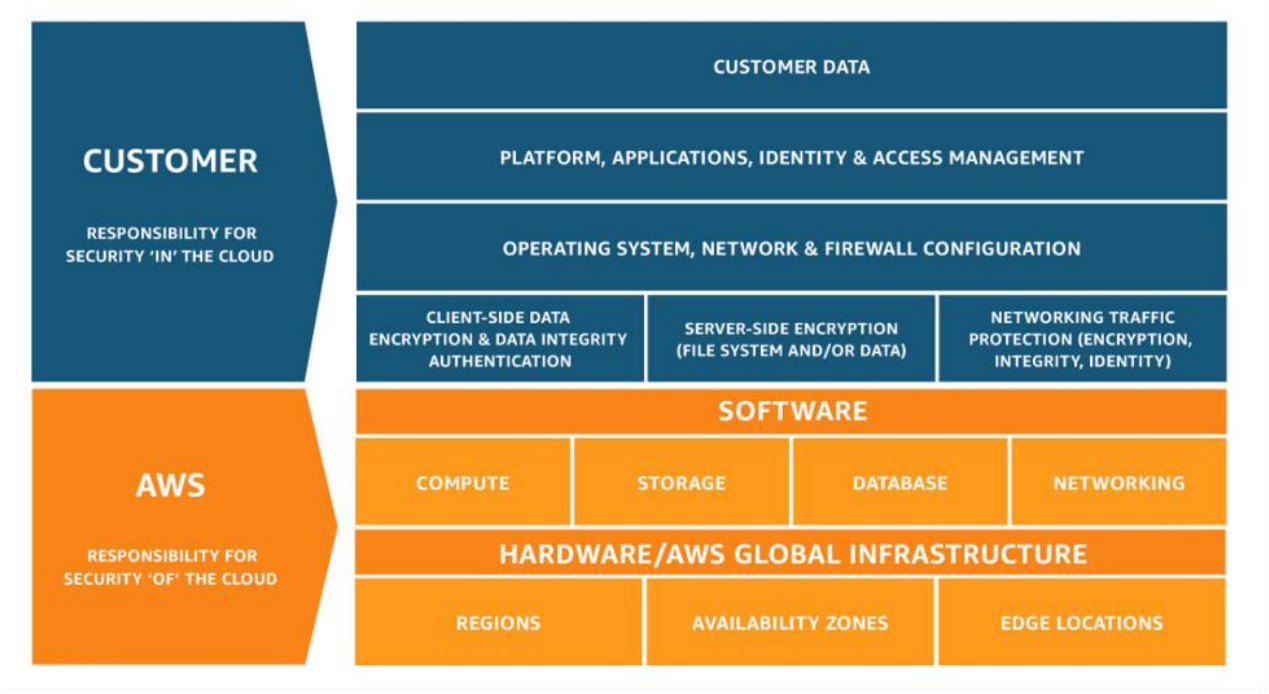


Figure 1: AWS Shared Responsibility Model

Types of Security Controls

Security controls within AWS can be categorized into three types based on how responsibilities are divided between AWS and the customer.

1. Inherited Controls

Inherited controls are security controls that are fully managed by AWS and automatically inherited by customers. Since AWS is responsible for the underlying cloud infrastructure, customers do not need to implement or manage these controls.

Examples:

- Physical security of data centers
- Environmental controls (power, cooling, fire suppression)

- Physical access controls
- Hardware maintenance and protection

Benefit: Customers can rely on AWS to maintain a secure infrastructure without managing these controls themselves.

2. Shared Controls

Shared controls are security controls where responsibilities are divided between AWS and the customer. AWS manages the controls related to the cloud infrastructure, while customers manage controls related to their workloads and applications.

Examples:

- **Patch Management:** AWS patches the infrastructure, while customers patch their operating systems and applications.
- **Configuration Management:** AWS maintains infrastructure configurations, while customers configure their operating systems, databases, and applications.
- **Security Monitoring and Logging:** AWS provides monitoring services, and customers use them to monitor their resources and activities.

Benefit: Shared controls allow both AWS and customers to contribute to maintaining a secure cloud environment.

3. Customer-Specific Controls

Customer-specific controls are entirely the responsibility of the customer. These controls depend on the applications, data, and business requirements of the organization.

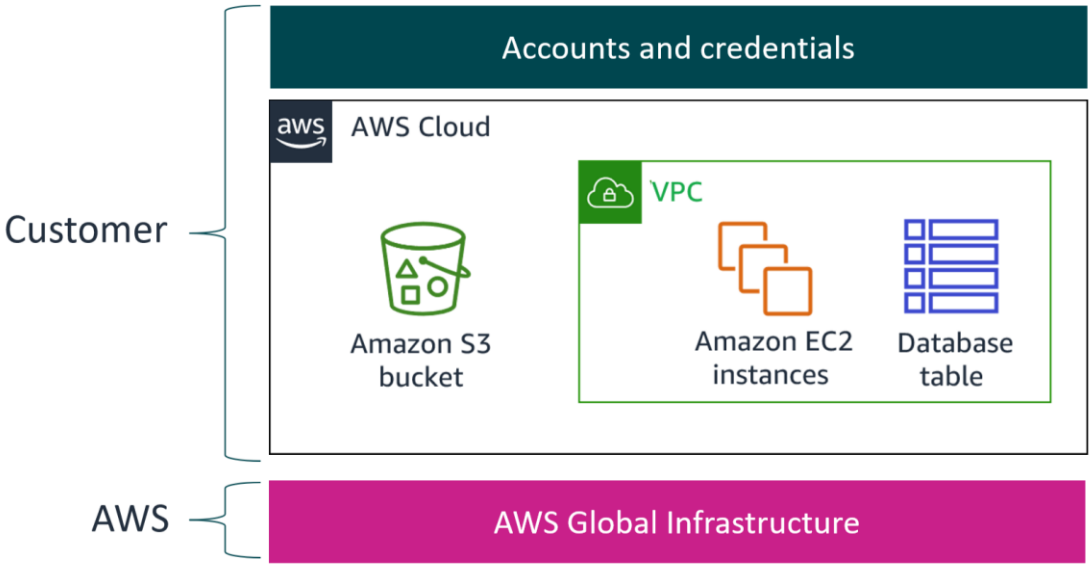
Examples:

- Data classification and protection
- Identity and access management (IAM) policies
- Application security
- Network segmentation and firewall configuration
- Data encryption settings
- Compliance with industry and regulatory requirements

Benefit: Customers retain full control over the security of their applications, data, and business processes.

R.M.K GROUP OF INSTITUTIONS

Shared Responsibility Example



Consider an example where a company uses Amazon S3 to store data. The AWS environment also includes Amazon EC2 instances and an Amazon RDS instance running a MySQL database within a Virtual Private Cloud (VPC). One EC2 instance hosts a web server, and the web application uses the database to store application data.

AWS Responsibilities

In this scenario, AWS is responsible for:

- Protecting the global infrastructure that hosts the services
- Securing the physical servers and storage hardware that support Amazon S3, Amazon EC2, and Amazon RDS
- Securing the physical networking infrastructure
- Managing and securing the hypervisor (virtualization layer) that hosts the EC2 instances

Customer Responsibilities

The customer is responsible for:

- Managing the guest operating system running on the EC2 instances, including operating system updates and security patches
- Managing application software and utilities installed on the EC2 instances
- Configuring security groups that control network access to the EC2 instances and the RDS database

R.M.K GROUP OF INSTITUTIONS

- Configuring security settings for the S3 bucket and stored objects
- Managing data protection measures such as encryption and access controls

For example, customers can use AWS security features such as bucket policies, data encryption, and S3 Block Public Access to secure data stored in Amazon S3.

This example illustrates the AWS Shared Responsibility Model, where AWS is responsible for securing the cloud infrastructure, while customers are responsible for securing their operating systems, applications, data, and configurations within the cloud.

5. IDENTITY AND ACCESS MANAGEMENT (IAM) FUNDAMENTALS

AWS Identity and Access Management (IAM) is a web service that helps securely control access to AWS resources. IAM enables organizations to manage **authentication** (who can access AWS resources) and **authorization** (what actions they can perform).

IAM is integrated with most AWS services, allowing administrators to define and manage access permissions from a central location. It supports fine-grained access control for users, groups, applications, and AWS services.

Key features of IAM include:

- Centralized access management across AWS services
- Fine-grained permission control
- Integration with existing identity systems such as Microsoft Active Directory
- Support for Multi-Factor Authentication (MFA)
- Activity logging and auditing through AWS CloudTrail

By using IAM, organizations can implement secure access controls while following the principle of least privilege.

What IAM Provides?

IAM provides two fundamental security functions:

Authentication

Authentication is the process of verifying the identity of a user or application attempting to access AWS resources.

Common authentication methods include:

R.M.K GROUP OF INSTITUTIONS

- Username and password
- Access keys
- Multi-Factor Authentication (MFA)
- Federated identities

Authorization

Authorization determines what actions an authenticated user or application is allowed to perform on AWS resources.

Examples include:

- Viewing resources
- Creating resources
- Modifying configurations
- Deleting resources

Authentication answers **"Who are you?"**, while authorization answers **"What are you allowed to do?"**

5.1 IAM Overview:

IAM uses four primary components to manage access control.

IAM User

An IAM user represents a person or application that interacts with AWS resources.

Characteristics:

- Has permanent credentials
- Can sign in to the AWS Management Console
- Can make programmatic requests using APIs or the AWS CLI

Example: Administrator, Developer, Database Administrator.

IAM Group

An IAM group is a collection of IAM users.

Groups simplify permission management by allowing administrators to assign permissions to multiple users simultaneously.

R.M.K GROUP OF INSTITUTIONS

Example:

- Developers Group
- Administrators Group
- Security Team Group

Users within a group automatically inherit the permissions assigned to that group.

IAM Role

An IAM role is an AWS identity that provides temporary security credentials.

Unlike IAM users, roles do not have permanent passwords or access keys. Roles can be assumed by users, applications, or AWS services when temporary access is required.

Examples:

- EC2 instance accessing an S3 bucket
- Lambda function accessing DynamoDB
- Cross-account access

IAM Policy

An IAM policy is a JSON document that defines permissions.

Policies specify:

- Allowed or denied actions
- AWS resources affected
- Conditions under which access is granted

Policies can be attached to:

- Users
- Groups
- Roles

5.2 IAM Terminology:

IAM Entity

IAM entities are AWS resource objects used for authentication. They represent identities that can sign in to AWS and make requests through the AWS Management Console, AWS APIs, or the AWS Command Line Interface (AWS CLI).

Examples:

- IAM Users
- IAM Roles

IAM Identity

IAM identities are AWS resource objects to which permissions can be assigned. Policies can be attached to IAM identities to control access to AWS resources.

Examples:

- Users
- Groups
- Roles

IAM Resource

IAM resources are the objects managed and stored within IAM. These resources can be created, modified, and deleted to manage access and security within an AWS account.

Examples:

- Users
- Groups
- Roles
- Policies
- Identity Providers

Principal

A principal is a person, application, or service that is authenticated and makes requests to AWS resources. A principal can use the AWS account root user, an IAM user, or an IAM role to access AWS services. Principals also include assumed roles and federated users.

Examples:

- AWS Account Root User
- IAM User
- IAM Role
- Assumed Role
- Federated User

A principal must be authenticated before AWS evaluates whether it is authorized to perform the requested action.

R.M.K GROUP OF INSTITUTIONS

5.3 IAM Requests:

Whenever a principal accesses AWS through the Management Console, API, or AWS CLI, a request is created.

A request contains:

- *Actions* or *operations* are what the principal wants to perform.
- *Resources* are the object or objects upon which the actions or operations are performed.
- The *principal* is the person or application using a user or role to send the request.
- *Environment data* consists of the IP address, user agent, Secure Sockets Layer (SSL) enabled status, or time of day.
- *Resource data* is the data related to the resource being requested.

AWS evaluates this information and decides whether to allow or deny the request.

Service Endpoints

To access an AWS service, requests are sent to a service endpoint, which acts as the entry point to that service.

Example:

ec2.us-east-1.amazonaws.com

This endpoint represents Amazon EC2 in the US East (N. Virginia) Region.

AWS SDKs and the AWS CLI automatically use the appropriate service endpoints when communicating with AWS services.

5.4 IAM Best Practices:

- Follow the **Principle of Least Privilege**
- Assign permissions through groups rather than individual users
- Use IAM roles whenever possible
- Enable Multi-Factor Authentication (MFA)
- Rotate credentials regularly
- Monitor activities using AWS CloudTrail
- Avoid using the root account for daily tasks

R.M.K GROUP OF INSTITUTIONS

6. AUTHENTICATING AND AUTHORIZING WITH IAM

6.1 Authenticating with IAM:

Authentication is the process of verifying the identity of a user, application, or service before granting access to AWS resources. AWS IAM provides several mechanisms to authenticate identities securely, including IAM roles, security credentials, and Multi-Factor Authentication (MFA).

6.1.1 IAM Roles:

An IAM role is an AWS identity that provides a set of permissions to access AWS resources. Unlike IAM users, roles do not have permanent credentials. Instead, they provide temporary security credentials that are issued when a user, application, or AWS service assumes the role.

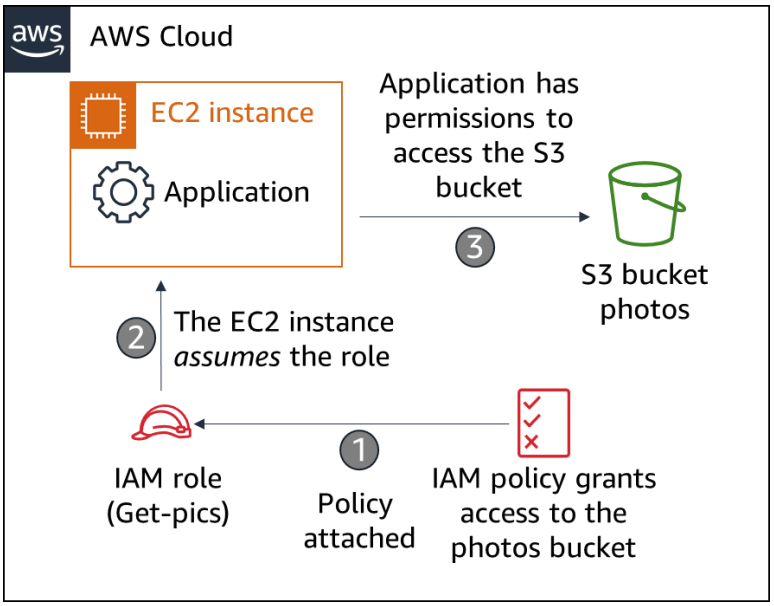
Characteristics of IAM Roles

- Provide temporary security credentials
- Not permanently associated with a specific user
- Can be assumed by users, applications, or AWS services
- Commonly used to delegate access
- Credentials are issued through **AWS Security Token Service (AWS STS)**
- Help eliminate the need for long-term access keys

Common Use Cases

- Applications running on Amazon EC2
- Cross-account access
- Mobile and web applications
- AWS service-to-service access

Example: IAM Role for Amazon S3 Access



Consider an application running on an EC2 instance that needs access to an Amazon S3 bucket.

1. An administrator creates a role named **Get-Pics**.
2. A policy granting access to an S3 bucket named **photos** is attached to the role.
3. The EC2 instance assumes the role.
4. AWS STS issues temporary security credentials.
5. The EC2 instance uses these credentials to access the **photos** bucket.

This approach avoids storing long-term credentials on the EC2 instance.

6.1.2 IAM Credentials for Authentication:

Whenever users or applications interact with AWS through the AWS Management Console, AWS CLI, SDKs, or APIs, they must provide valid security credentials.

Types of Authentication Credentials

Console Access

Users authenticate using:

- Username
- Password
- Multi-Factor Authentication (optional but recommended)

Programmatic Access

Applications and automated tools authenticate using:

- Access Key ID
- Secret Access Key

R.M.K GROUP OF INSTITUTIONS

These credentials are used when accessing AWS through:

- AWS CLI
- AWS SDKs
- AWS APIs

AWS uses these credentials to authenticate the requester and determine whether the requested action is authorized.

Types of AWS Identities and Credentials

AWS supports different types of identities, each using either long-term or temporary credentials.

Long-Term Credentials

Used by:

- Root User
- IAM Users
- Access Keys

Characteristics:

- Do not expire automatically
- Require password management and key rotation
- Should be protected using MFA

Temporary Credentials

Used by:

- IAM Roles
- AWS IAM Identity Center Users
- Federated Users
- AWS STS Sessions

Characteristics:

- Valid for a limited duration
- Generated dynamically when required
- Expire automatically after the session ends

Benefits of Temporary Credentials

- No need to store permanent access keys
- Reduced security risk

R.M.K GROUP OF INSTITUTIONS

- Support for federation and cross-account access
- Automatically expire when no longer needed

Because of these advantages, AWS recommends using temporary credentials whenever possible.

6.1.3 Multi-Factor Authentication (MFA):

Multi-Factor Authentication (MFA) is a security mechanism that requires users to provide an additional verification factor during sign-in.

Benefits of MFA

- Adds an extra layer of protection
- Reduces the risk of unauthorized access
- Protects accounts even if passwords are compromised

Authentication Factors

MFA combines two or more of the following:

- **Something you know** – Password or PIN
- **Something you have** – Security token or mobile device
- **Something you are** – Biometric information such as a fingerprint

MFA Process

When MFA is enabled:

1. The user enters a username and password.
2. AWS requests an authentication code.
3. The user provides the code generated by an MFA device.
4. Access is granted only after successful verification.

Examples of MFA Devices

Hardware-Based Devices

- YubiKey
- Gemalto Security Keys

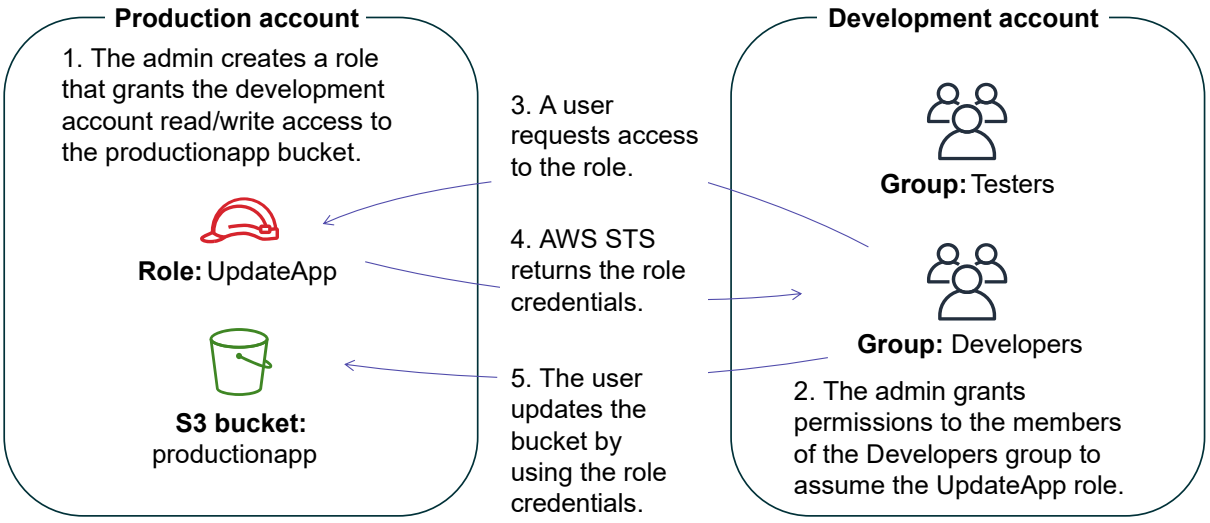
Virtual MFA Applications

- Google Authenticator
- Authy

AWS recommends enabling MFA for all privileged accounts, especially the root user.

R.M.K GROUP OF INSTITUTIONS

Authentication Scenario: Cross-Account Access Using IAM Roles



Consider an organization with separate AWS accounts for development and production environments. Developers need temporary access to update an S3 bucket named **productionapp** in the production account.

The authentication process is as follows:

1. An administrator in the production account creates an IAM role named **UpdateApp** and configures a trust policy that allows the development account to assume the role.
2. An administrator in the development account grants members of the **Developers** group permission to assume the **UpdateApp** role.
3. A developer requests access to the role through the AWS Management Console, AWS CLI, or API.
4. AWS Security Token Service (AWS STS) verifies the request and issues temporary security credentials.
5. Using the temporary credentials, the developer gains temporary access to update the **productionapp** S3 bucket in the production account.

This approach provides secure, temporary access without sharing long-term credentials between AWS accounts.

R.M.K GROUP OF INSTITUTIONS

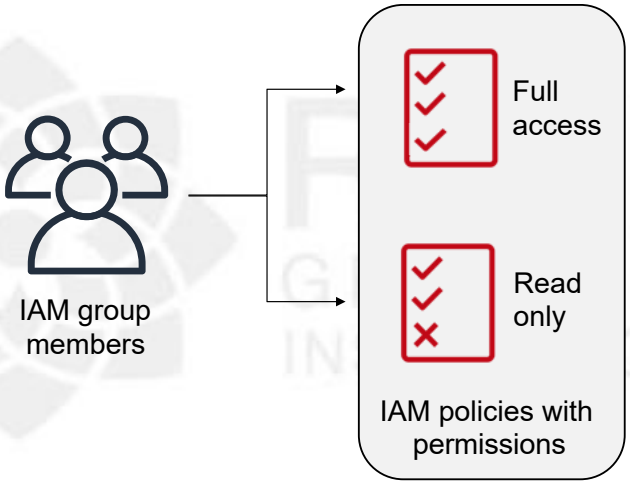
6.2 Authorizing with IAM:

6.2.1 Principle of least privilege:

When granting permissions to users, groups, roles, and resources, organizations should follow the principles of strong authentication and least privilege. The principle of least privilege ensures that only the minimum permissions required to perform a specific task are granted.

A recommended approach is to begin with a limited set of permissions and add privileges only when necessary. This method provides stronger security than granting broad permissions initially and attempting to restrict them later. Determining the appropriate permissions requires analyzing the tasks that users need to perform and assigning only the access required for those tasks.

For example, developers may be granted permission to launch Amazon EC2 instances in a production environment while being restricted from stopping or terminating those instances.



6.2.2 Policies and permissions:

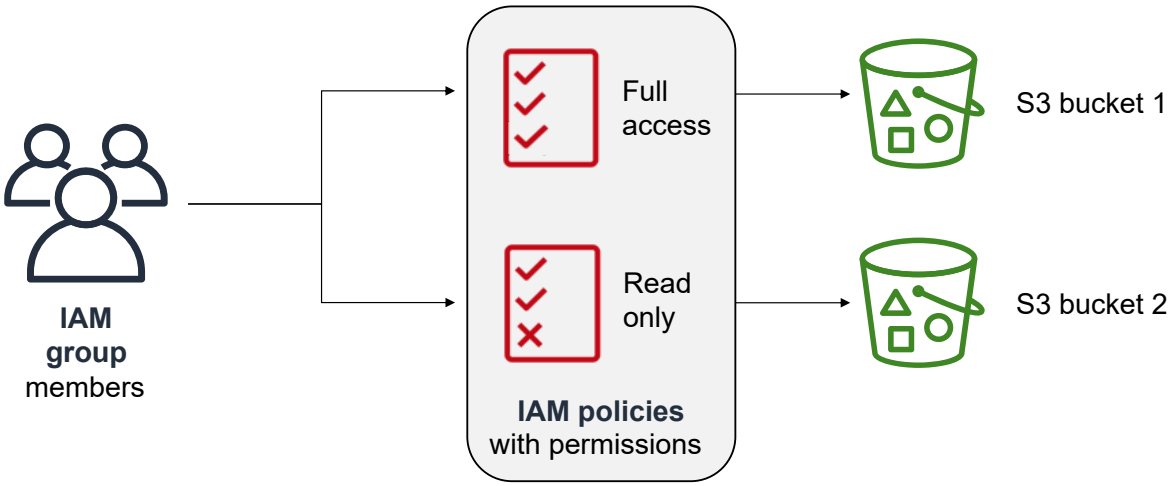
AWS Identity and Access Management (IAM) enables administrators to control access to AWS resources through policies that either allow or deny permissions.

By default, an authenticated IAM user, group, or role has no access to AWS resources until permissions are explicitly granted. Permissions are assigned through policies, which are documents that define:

- **Effect** (Allow or Deny)
- **Actions** (Operations that can be performed)
- **Resources** (AWS resources affected)
- **Conditions** (Optional constraints under which permissions apply)

Most IAM policies are written in **JavaScript Object Notation (JSON)** format. Any action or

resource that is not explicitly allowed is denied by default. Whenever an IAM principal (user or role) submits a request, AWS evaluates all applicable policies to determine whether the request should be allowed or denied.



Types of AWS Policies

AWS supports several policy types, each serving a specific purpose:

1. Identity-Based Policies

- Attached to IAM users, groups, or roles.
- Define the permissions granted to an identity.
- Can be managed or inline policies.

2. Resource-Based Policies

- Attached directly to AWS resources.
- Specify which principals can access the resource and what actions they can perform.
- Common examples include Amazon S3 bucket policies and IAM role trust policies.

3. VPC Endpoint Policies

- Attached to VPC endpoints.
- Control which principals can use the endpoint and which resources can be accessed through it.

4. Permissions Boundaries

- Define the maximum permissions that identity-based policies can grant to a user or role.
- Do not grant permissions by themselves.

5. AWS Organizations Service Control Policies (SCPs)

R.M.K GROUP OF INSTITUTIONS

- Define the maximum permissions available to IAM users and roles within AWS accounts that belong to an organization or organizational unit (OU).
- Restrict permissions but do not grant them.

6. AWS Organizations Resource Control Policies (RCPs)

- Define the maximum permissions available to resources within AWS accounts that belong to an organization or OU.
- Restrict permissions granted by identity-based and resource-based policies.

7. Access Control Lists (ACLs)

- Used to grant cross-account access to specific resources.
- Unlike other policy types, ACLs do not use JSON format.
- Cannot grant permissions to entities within the same AWS account.

8. AWS Resource Access Manager (RAM) Resource Shares

- Enable secure sharing of resources across AWS accounts, organizational units, or entire organizations without creating individual resource-based policies.

9. Session Policies

- Used when assuming roles or creating federated user sessions through the AWS CLI or AWS API.
- Restrict permissions available during a temporary session.
- Cannot grant permissions independently.

6.2.3 Identity-based and resource-based policies:

AWS IAM provides two primary policy types that can grant permissions: **Identity-Based Policies** and **Resource-Based Policies**. The key difference between them lies in where the policy is attached and how permissions are granted.

Identity-Based Policies

Identity-based policies are attached to IAM identities such as users, groups, or roles. These policies define the actions that an identity is permitted to perform on AWS resources.

For example, an IAM user can be granted permission to launch Amazon EC2 instances, access a DynamoDB table, or manage their own security credentials. Identity-based policies can be implemented as either managed policies or inline policies.

R.M.K GROUP OF INSTITUTIONS

Carlos

Resource	Read	Write	List
Resource X	Allow	Allow	Allow

Richard

Resource	Read	Write	List
Resource Y	Allow	N/A	N/A
Resource Z	Allow	N/A	N/A

Managers

Resource	Read	Write	List
Resource X	N/A	N/A	Allow
Resource Y	N/A	N/A	Allow
Resource Z	N/A	N/A	Allow

Resource-Based Policies

Resource-based policies are attached directly to AWS resources. They specify which users, roles, accounts, or services can access a resource and what actions they are allowed to perform. Common examples include Amazon S3 bucket policies, Amazon SQS queue policies, AWS KMS key policies, and VPC endpoint policies. Resource-based policies are particularly useful for granting cross-account access between trusted AWS accounts. Unlike identity-based policies, resource-based policies are always inline and cannot be managed separately.

Resource X

User	Read	Write	List
Ana	Allow	Allow	Allow
Akua	Allow	Allow	Allow
Mary	Allow	N/A	Allow
Mateo	N/A	N/A	Allow

Resource Y

User	Read	Write	List
Paulo	Allow	Allow	Allow
Nikki	Allow	N/A	N/A
Mateo	N/A	Allow	Allow

R.M.K GROUP OF INSTITUTIONS

6.2.4 Managed and Inline IAM Policies:

IAM policies can be categorized into **Managed Policies** and **Inline Policies**.

Managed Policies

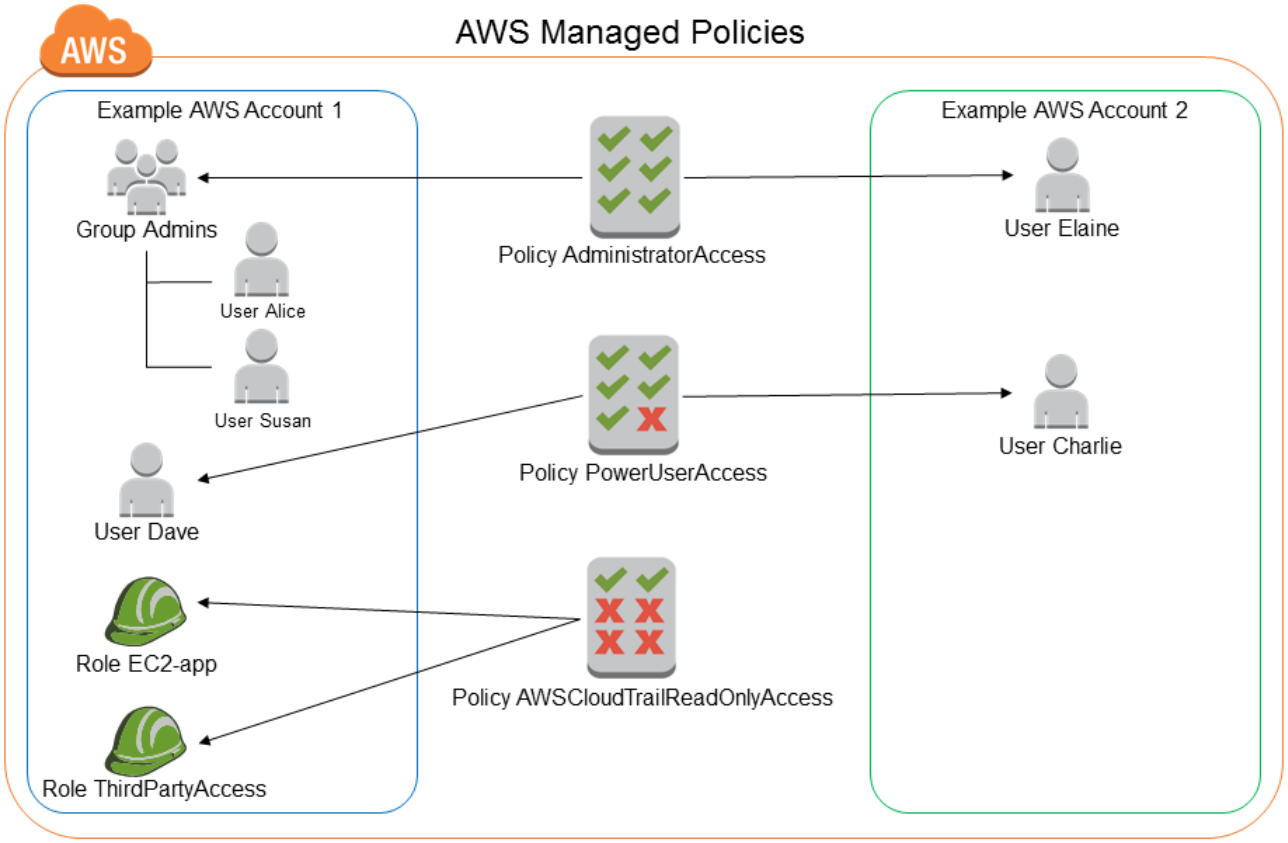
Managed policies are standalone identity-based policies that can be attached to multiple IAM users, groups, and roles.

There are two types of managed policies:

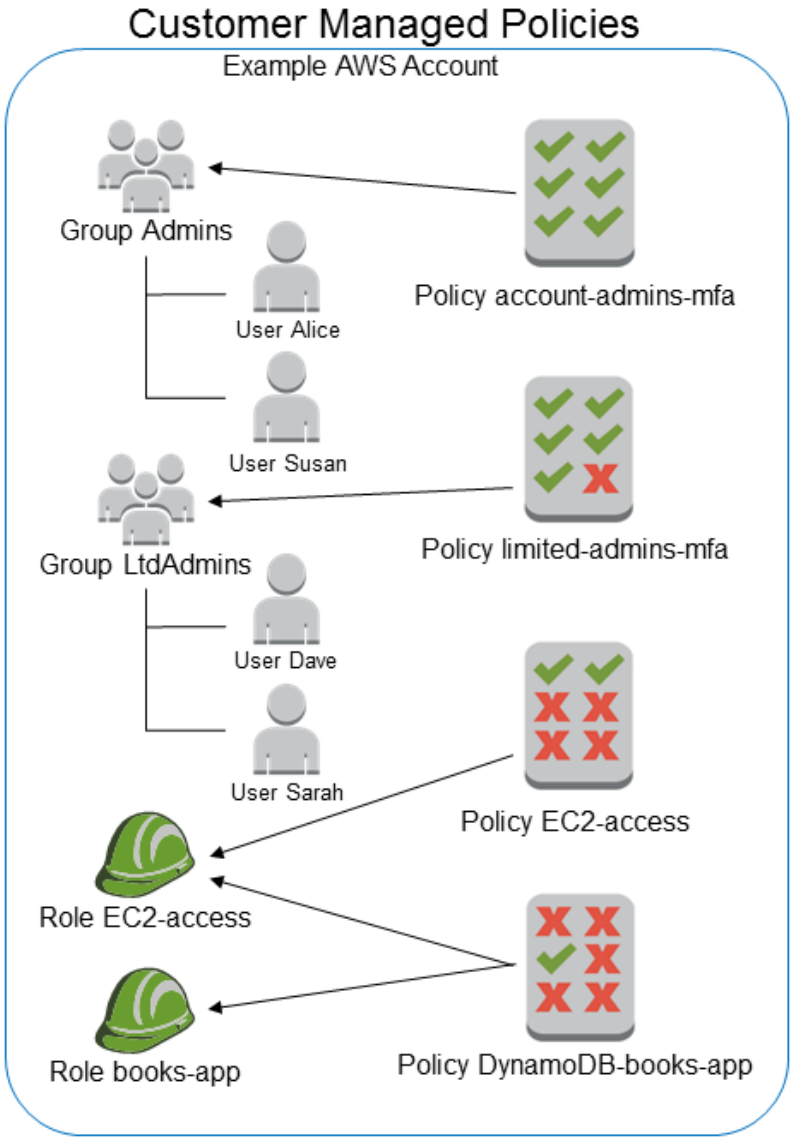
- **AWS Managed Policies** – Created and maintained by AWS.
- **Customer Managed Policies** – Created and maintained by AWS customers.

Managed policies offer several advantages, including:

- Reusability across multiple identities
- Centralized policy management
- Version control and rollback capabilities
- Delegation of permissions management
- Support for permissions boundaries



Permissions boundaries are advanced managed policies that define the maximum permissions an identity-based policy can grant to a user or role.



Inline Policies

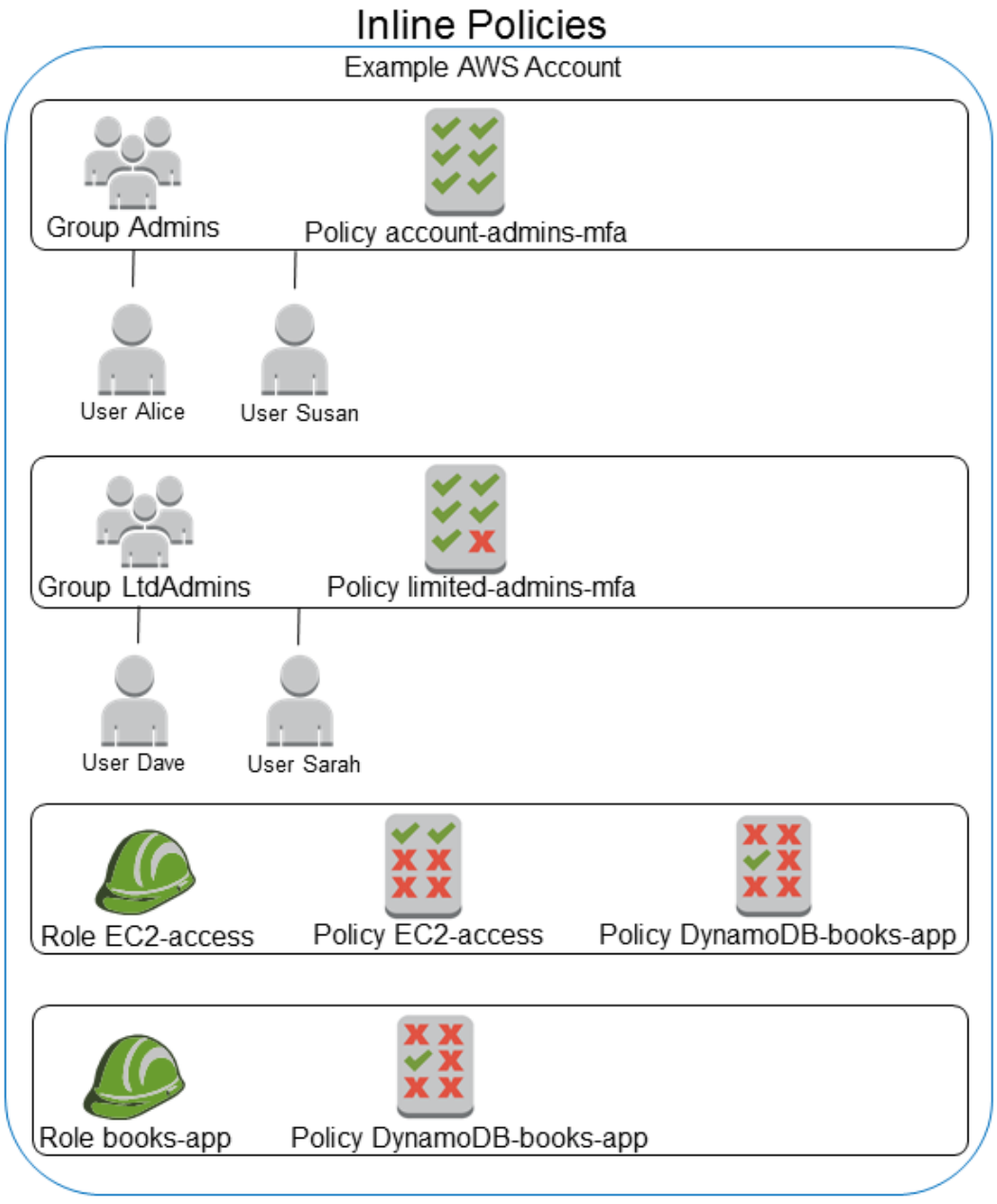
Inline policies are embedded directly within a single IAM user, group, or role. They maintain a strict one-to-one relationship with the identity to which they are attached.

Characteristics of inline policies include:

- Stored as part of the IAM identity
- Cannot be shared among multiple users, groups, or roles
- Difficult to manage centrally because each identity maintains its own policy copy
- Prevent accidental attachment to unintended identities

R.M.K GROUP OF INSTITUTIONS

Inline policies are useful when permissions must remain tightly coupled to a specific IAM entity. However, AWS generally recommends using managed policies whenever possible due to their flexibility and ease of management.



6.2.5 Evaluation Logic for IAM Policies:

Whenever a user, role, or service makes a request to AWS, IAM evaluates all applicable policies to determine whether the requested action is allowed or denied.

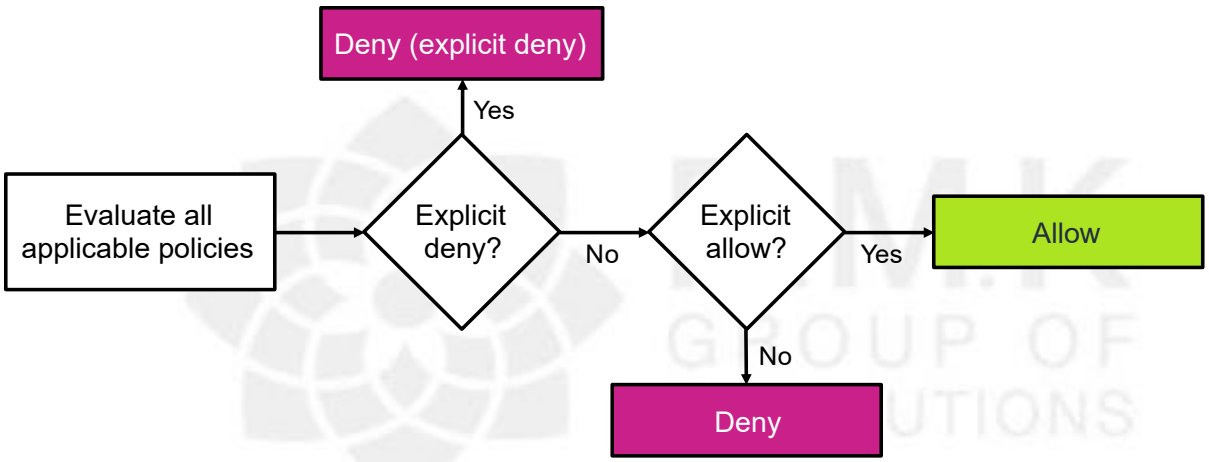
AWS follows the following evaluation logic:

1. **Default Deny** – All requests are denied by default.

2. **Explicit Allow** – If a policy explicitly allows the requested action, the request is permitted.
3. **Explicit Deny** – If any policy explicitly denies the action, the request is denied regardless of any allow statements.

Important Rules

- Every request starts with an implicit deny.
- An explicit allow overrides the default deny.
- An explicit deny overrides any explicit allow.
- AWS evaluates all applicable policies before making a final decision.
- The order in which policies are evaluated does not affect the outcome.



7. EXAMPLES OF AUTHORIZING WITH IAM

Example: Identity-based policy

An **identity-based policy** is attached to an IAM user, group, or role and specifies the actions that the identity is allowed or denied to perform.

```
{
   "Version": "2018-10-17",
   "Statement": {
         "Effect": "Allow",
         "Action": [
               "iam:*LoginProfile",
               "iam:*AccessKey*",
               "iam:*SSHPublicKey*"
```

```
            ],
            "Resource": "arn:aws:iam::account-id-without-hyphens:user/${aws:username}"
        }
    }
```

After this policy is attached to an IAM entity, the entity is granted permission to manage specific IAM credentials associated with its own user account.

The policy allows a user to:

- Create, retrieve, update, or delete their own password using IAM LoginProfile actions.
- Create, list, update, or delete their own access keys using IAM AccessKey actions.
- Create, retrieve, list, update, or delete their own Secure Shell (SSH) public keys using IAM SSHPublicKey actions.

The asterisk (*) acts as a wildcard, enabling multiple related actions to be specified with a single entry. The ${aws:username} variable dynamically inserts the current user's name, ensuring that users can manage only their own credentials.

Example: Cross-account, resource-based policy

A **resource-based policy** is attached directly to an AWS resource and defines which principals can access the resource and what actions they can perform.

```
{
   "Version": "2018-10-17",
   "Statement": {
         "Sid": "AccountBAccess1",
         "Principal": {"AWS": "111122223333"},
         "Effect": "Allow",
         "Action": "s3:*",
         "Resource": [
               "arn:aws:s3:::DOC-EXAMPLE-BUCKET",
               "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"
         ]
   }
}
```

This policy is attached to an Amazon S3 bucket owned by **Account A**. It grants **Account B** (AWS Account ID: 111122223333) permission to perform all Amazon S3 operations on the specified

bucket and its contents.

Key points:

- The policy grants access at the AWS account level rather than to specific IAM users or roles.
- The wildcard (s3:*) allows all Amazon S3 actions.
- Both the bucket and all objects within the bucket are included in the resource list.
- To use this access, Account B must also create an appropriate IAM policy granting its users permission to access the bucket.

This approach is commonly used for secure cross-account resource sharing.

Example IAM policy: Allow statement

The following policy grants access only to specific DynamoDB and Amazon S3 resources.

```
{
   "Version": "2012-10-17",
   "Statement":[{
            "Effect":"Allow",
            "Action":["dynamodb:*","s3:*"],
            "Resource":["arn:aws:dynamodb:region:account-number-without-
hyphens:table/coursenotes",
                     "arn:aws:s3:::course-notes-web",
                     "arn:aws:s3:::course-notes-mp3/*"]
            },
            {
            "Effect":"Deny",
            "Action":["dynamodb:*","s3:*"],
            "NotResource":["arn:aws:dynamodb:region:account-number-without-
hyphens:table/coursenotes",
                     "arn:aws:s3:::course-notes-web",
                     "arn:aws:s3:::course-notes-mp3/*"]
            }
   ]
}
```

This policy allows users to perform all DynamoDB and Amazon S3 operations on:

- The DynamoDB table **coursenotes**
- The S3 bucket **course-notes-web**

- The S3 bucket **course-notes-mp3** and all objects stored within it

The permissions apply only to the resources explicitly listed in the policy.

Example IAM policy: Deny statement

```
{
   "Version": "2012-10-17",
   "Statement":[{
         "Effect":"Allow",
         "Action":["dynamodb:*","s3:*"],
         "Resource":["arn:aws:dynamodb:region:account-number-without-hyphens:table/coursenotes",
               "arn:aws:s3:::course-notes-web",
               "arn:aws:s3:::course-notes-mp3/*"]
         },
         {
         "Effect":"Deny",
         "Action":["dynamodb:*","s3:*"],
         "NotResource":["arn:aws:dynamodb:region:account-number-without-hyphens:table/coursenotes",
               "arn:aws:s3:::course-notes-web",
               "arn:aws:s3:::course-notes-mp3/*"]
         }
   ]
}
```

The first statement grants access to the specified DynamoDB table and S3 resources.

The second statement explicitly denies access to all other DynamoDB tables and S3 buckets that are not listed in the policy. The NotResource element identifies resources that are exempt from the deny rule.

This policy ensures that users:

- Can access only the approved DynamoDB and S3 resources.
- Cannot access any other DynamoDB tables or S3 buckets within the account.
- Remain restricted even if another policy attempts to grant additional permissions, because an **explicit deny always overrides an allow**.

This is a common security practice for enforcing strict access control.

R.M.K GROUP OF INSTITUTIONS

Example IAM policy: Permissions boundary

Policy 1:

```
{
    "Version":"2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": [
                "s3:*",
                "cloudwatch:*",
                "ec2:*"
            ],
            "Resource": "*"
        }
    ]
}
```

Policy 2:

```
{
  "Version":"2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": "iam:CreateUser",
    "Resource": "*"
  }
}
```

Assume that both policies are attached to an IAM user named **ExampleUser**, with Policy 1 serving as the permissions boundary.

Policy 1 allows actions only within:

- Amazon S3
- Amazon CloudWatch
- Amazon EC2

Policy 2 grants permission to perform the iam:CreateUser operation.

Although Policy 2 explicitly allows the creation of IAM users, the operation will fail because the permissions boundary does not allow access to IAM services. Since permissions boundaries define the maximum permissions available to an entity, the effective permissions are the intersection of both policies.

Therefore, an IAM entity can perform only actions that are allowed by:

1. Its identity-based policies, and
2. Its permissions boundary.

To enable the iam:CreateUser operation, the permissions boundary must also include permission to access IAM resources.

8. ADDITIONAL AUTHENTICATION AND ACCESS MANAGEMENT SERVICES

Identity Federation:

Identity federation is a trust-based mechanism that enables users to access resources across different systems without requiring separate credentials for each system. It establishes a relationship between an **Identity Provider (IdP)** and a **Service Provider (SP)**.

- The **Identity Provider (IdP)** is responsible for authenticating users.
- The **Service Provider (SP)** is responsible for authorizing access to resources.
- Once a trust relationship is established, the service provider accepts the authentication performed by the identity provider and grants access to authorized resources.

AWS offers two primary services to support identity federation:

- **AWS Single Sign-On (AWS SSO)**
- **AWS Identity and Access Management (IAM)**

AWS SSO is generally suitable for organizations that use a centralized directory for managing users. IAM federation is often preferred when multiple directories are involved or when attribute-based access control is required.

AWS Single Sign-On (AWS SSO):

AWS Single Sign-On (AWS SSO) enables organizations to centrally manage user identities and permissions across multiple AWS accounts and cloud applications.

Key Features

- Create or connect user identities once and manage access centrally.
- Define, customize, and assign fine-grained permissions based on job roles and responsibilities.
- Provide users with a centralized portal to access assigned AWS accounts and applications.

R.M.K GROUP OF INSTITUTIONS

- Configure access to complement or replace traditional IAM-based account access management.
- Support integration with popular cloud applications such as Microsoft 365 and Salesforce.

AWS SSO simplifies access management by providing a unified administrative experience. Users can sign in using their existing directory credentials and access all authorized AWS accounts and applications through a single user portal. This approach reduces administrative overhead and improves user experience while maintaining security and access control.

AWS Directory Service:

AWS Directory Service for Microsoft Active Directory, commonly known as **AWS Managed Microsoft AD**, enables organizations to use Microsoft Active Directory within the AWS Cloud.

Key Features

- Supports directory-aware applications and AWS resources.
- Provides a managed Microsoft Active Directory environment in AWS.
- Enables extension of existing on-premises Active Directory environments to the cloud.
- Allows users to access AWS resources using their existing Active Directory credentials.
- Supports Single Sign-On (SSO) across AWS applications and services.

AWS Managed Microsoft AD is built on Microsoft Active Directory technology and eliminates the need to synchronize or replicate existing directory data manually. Organizations can leverage their current Active Directory infrastructure while seamlessly extending access to AWS resources, simplifying user management and authentication.

Amazon Cognito:

Amazon Cognito is a fully managed service that provides authentication, authorization, and user management capabilities for web and mobile applications.

Key Features

- Supports user sign-up, sign-in, and access control.
- Provides a secure and scalable identity store capable of supporting millions of users.
- Enables authentication through enterprise identity providers and social identity providers such as Apple, Google, Facebook, and Amazon.
- Creates unique user identities and federates them with external identity providers.

R.M.K GROUP OF INSTITUTIONS

- Supports Multi-Factor Authentication (MFA), phone verification, and enhanced security features.

Amazon Cognito consists of two primary components:

User Pools

User pools act as user directories that manage registration and authentication for application users.

Functions of user pools include:

- User registration and sign-in
- Password management
- Multi-Factor Authentication (MFA)
- Account verification through email or phone
- Integration with social and enterprise identity providers

Identity Pools

Identity pools enable authenticated and guest users to obtain temporary AWS credentials.

Functions of identity pools include:

- Granting secure access to AWS services and resources
- Providing temporary, limited-privilege AWS credentials
- Federating identities from user pools and external identity providers

By combining user pools and identity pools, Amazon Cognito provides a comprehensive solution for authentication, authorization, and secure access management in modern web and mobile applications.

9. USING AWS ORGANIZATIONS

AWS Organizations:

AWS Organizations is an account management service that enables organizations to centrally manage multiple AWS accounts. It simplifies account administration by providing centralized account creation, governance, and billing management.

Key Features

- **Centralized Account Management:** Create and manage multiple AWS accounts from a single location.

R.M.K GROUP OF INSTITUTIONS

- **Consolidated Billing:** Combine billing information from multiple accounts into a single bill, making cost management easier.
- **Organizational Units (OUs):** Group accounts hierarchically based on departments, projects, environments, or business requirements.
- **Service Control Policies (SCPs):** Apply organization-wide permission boundaries to control access across accounts.
- **Integration with IAM:** Works alongside IAM to provide an additional layer of access control at the account level.

Organizations allow administrators to create a structured hierarchy by placing accounts into Organizational Units (OUs). Different policies can then be applied to individual accounts or groups of accounts based on organizational requirements.

Service Control Policies (SCPs):

A **Service Control Policy (SCP)** is an organization policy used to define the maximum permissions available to IAM users and roles within AWS accounts that are part of an organization.

- SCPs do **not grant permissions**.
- SCPs only **restrict or limit permissions**.
- They act as **guardrails** that define what actions are allowed within member accounts.
- Effective permissions are determined by the intersection of:
    - Permissions allowed by SCPs
    - Permissions granted by IAM policies and resource-based policies

Therefore, a user can perform an action only if it is allowed by both the SCP and the IAM policy.

Example: Prevent Member Accounts from Leaving the Organization

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [
        "organizations:LeaveOrganization"
```

```
      ],
      "Resource": "*"
    }
  ]
}
```

Explanation

This SCP explicitly denies the **organizations:LeaveOrganization** action.

As a result:

- Member accounts cannot leave the AWS Organization.
- The restriction applies even if an IAM policy grants permission to perform this action.
- The explicit deny acts as a safeguard to ensure that accounts remain under organizational governance.

Policies in AWS Organizations:

AWS Organizations provides various policy types that help administrators centrally manage security, governance, compliance, and service configurations across multiple AWS accounts. These policies can be used only when **all features** are enabled in the organization.

The policies are broadly classified into two categories:

1. Authorization Policies

Authorization policies help control permissions and access across the organization.

Service Control Policies (SCPs)

- Define the **maximum permissions** available to IAM users and roles within member accounts.
- Act as permission guardrails.
- Cannot grant permissions; they only restrict them.

Resource Control Policies (RCPs)

- Define the **maximum permissions** available to resources within member accounts.
- Help enforce organization-wide resource-level access controls.
- Work alongside IAM and resource-based policies.

2. Declarative Policies

R.M.K GROUP OF INSTITUTIONS

Declarative policies help centrally configure and enforce AWS service settings across accounts.

Amazon EC2 Policies

- Enforce consistent Amazon EC2 configurations across the organization.
- Automatically maintain desired configurations even when new features are introduced.

Backup Policies

- Centrally manage and apply backup plans to AWS resources across multiple accounts.

Tag Policies

- Standardize resource tagging across the organization.
- Improve governance, cost tracking, and resource management.

Chat Applications Policies

- Control access to AWS accounts from collaboration platforms such as Slack and Microsoft Teams.

AI Services Opt-Out Policies

- Manage data collection preferences for AWS AI and machine learning services across all accounts.

Security Hub Policies

- Centrally configure and enforce security controls and compliance requirements using AWS Security Hub.

Amazon Inspector Policies

- Enable and manage Amazon Inspector vulnerability assessments across organizational accounts.

Amazon Bedrock Policies

- Enforce Amazon Bedrock Guardrails and AI safety controls across the organization for all model inference requests.

Upgrade Rollout Policies

- Control and schedule automatic service upgrades across multiple AWS accounts and resources.

Amazon S3 Policies

- Centrally manage and enforce Amazon S3 configuration settings and governance requirements across organizational accounts.

R.M.K GROUP OF INSTITUTIONS

10. ASSIGNMENT

Assignment 1: Cloud Security Fundamentals Analysis

Difficulty Level: Beginner

Topic: Introduction to Security and Security in the Cloud

Task: Analyze the security requirements of a cloud-based application.

Instructions:

1. Select a cloud-based application such as online banking, e-commerce, or healthcare management.
2. Identify potential security threats associated with the application.
3. Explain the importance of Confidentiality, Integrity, and Availability (CIA Triad) in the chosen application.
4. Discuss how cloud computing introduces additional security challenges.
5. Document your findings with suitable examples.

Expected Output: A report describing cloud security requirements, threats, and mitigation strategies.

Assignment 2: Security Design Principles Case Study

Difficulty Level: Intermediate

Topic: Security Design Principles

Task: Apply security design principles to a cloud deployment scenario.

Instructions:

1. Consider a cloud-hosted university management system.
2. Analyze the system using the following security design principles:
    - Least Privilege
    - Defense in Depth
    - Separation of Duties
    - Fail-Safe Defaults
3. Identify potential security weaknesses.
4. Recommend improvements based on the selected principles.
5. Present your findings with supporting diagrams.

R.M.K GROUP OF INSTITUTIONS

Expected Output: A case study report demonstrating the application of security design principles to improve cloud security.

Assignment 3: Shared Responsibility Model Assessment

Difficulty Level: Intermediate

Topic: Shared Responsibility Model

Task: Compare security responsibilities across different cloud service models.

Instructions:

1. Select one example each for IaaS, PaaS, and SaaS.
2. Create a responsibility matrix showing customer and cloud provider responsibilities.
3. Identify security controls managed by the provider and those managed by the customer.
4. Analyze how responsibilities change across the three service models.
5. Summarize the advantages and challenges of each model.

Expected Output: A responsibility matrix and comparative report illustrating the Shared Responsibility Model.

Assignment 4: IAM Implementation and Access Control

Difficulty Level: Advanced

Topic: IAM Fundamentals, Authentication and Authorization

Task: Design and implement Identity and Access Management policies for a hypothetical organization.

Instructions:

1. Create a cloud organization consisting of:
    - Administrators
    - Developers
    - Security Auditors
    - Business Analysts
2. Define users, groups, and roles for each category.
3. Design IAM policies based on the principle of least privilege.
4. Configure authentication mechanisms such as MFA.

R.M.K GROUP OF INSTITUTIONS

5. Document policy definitions and justify access permissions assigned to each role.

Expected Output: IAM policy documentation, access control matrix, and screenshots demonstrating policy implementation.

Assignment 5: Enterprise Cloud Governance and IAM Architecture

Difficulty Level: Expert

Topic: IAM, Authentication Services, Authorization, and Organizations

Task: Design a secure multi-account cloud governance framework.

Instructions:

1. Consider a multinational enterprise with separate departments for Finance, HR, Research, and Operations.
2. Design an organizational hierarchy using AWS Organizations.
3. Create Organizational Units (OUs) and define account structures.
4. Develop IAM roles, permission boundaries, and service control policies (SCPs).
5. Recommend authentication services such as MFA, Single Sign-On (SSO), and identity federation.
6. Prepare an architecture diagram showing governance and access control mechanisms.
7. Justify how the proposed design enhances security and compliance.

Expected Output: A cloud governance architecture report containing organizational structure, IAM design, security policies, and architecture diagrams.

11. PART A QUESTIONS AND ANSWERS

1.	**What is cloud security?** Cloud security is the collection of technologies, policies, controls, and procedures used to protect cloud-based data, applications, and infrastructure. It helps ensure confidentiality, integrity, and availability of resources while preventing unauthorized access and cyberattacks.	K1
2.	**Why is cloud security important?** Cloud security is important because cloud resources are accessible over the internet and are exposed to various cyber threats. It protects critical business assets, sensitive information, and applications from attacks, data breaches, and unauthorized access.	K1
3.	**State any two benefits of cloud security.** Cloud security provides strong protection for data through encryption and access controls. It also helps organizations meet regulatory compliance requirements while reducing the cost of maintaining secure physical infrastructure.	K1
4.	**What is meant by the erasure of the physical perimeter?** In traditional environments, security relied on physical data centers and network boundaries. In cloud computing, resources are accessed through the internet, making identity management and access control the primary security perimeter.	K2
5.	**What are the seven areas of cloud security?** The seven areas of cloud security are Security Foundations, Identity and Access Management, Detection, Infrastructure Protection, Data Protection, Incident Response, and Application Security. Together, they provide comprehensive protection for cloud environments.	K1
6.	**Define the CIA Triad.** The CIA Triad is the fundamental model of information security consisting of Confidentiality, Integrity, and Availability. These three principles help organizations protect data and maintain secure information systems.	K1
7.	**What is confidentiality?**	K1

	Confidentiality ensures that sensitive information is accessible only to authorized users. It prevents unauthorized disclosure of data through mechanisms such as encryption, authentication, and access control.	
8.	**What is integrity?** Integrity ensures that data remains accurate, complete, and trustworthy throughout its lifecycle. It protects information from unauthorized modifications and helps verify the authenticity of data sources.	K1
9.	**What is availability?** Availability ensures that systems, applications, and information are accessible whenever authorized users require them. High availability minimizes downtime and supports continuous business operations.	K1
10.	**What is controllability in AWS Cloud Security?** Controllability refers to managing who can access AWS resources and what actions they are permitted to perform. AWS IAM services help organizations implement secure authentication and fine-grained access controls.	K2
11.	**What is auditability in AWS Cloud Security?** Auditability enables organizations to track and review activities performed within AWS environments. AWS CloudTrail records user actions and API calls, supporting compliance, auditing, and security investigations.	K2
12.	**What is visibility in AWS Cloud Security?** Visibility provides insight into AWS resources, configurations, and user activities. AWS Config helps monitor resources, track configuration changes, and identify potential security issues.	K2
13.	**What is agility and automation in AWS Cloud Security?** Agility and automation enable organizations to rapidly deploy and secure cloud resources. AWS services support automated scaling, monitoring, and infrastructure deployment, improving efficiency and consistency.	K2
14.	**What is the principle of least privilege?** The principle of least privilege states that users should be granted only the permissions	K2

R.M.K GROUP OF INSTITUTIONS

	necessary to perform their assigned tasks. This minimizes security risks and reduces the impact of compromised accounts.	
15.	**What is meant by maintaining traceability?** Maintaining traceability involves monitoring, logging, and auditing activities within cloud environments. Services such as AWS CloudTrail and CloudWatch help organizations detect suspicious activities and support forensic investigations.	K2
16.	**What is the AWS Shared Responsibility Model?** The AWS Shared Responsibility Model divides security responsibilities between AWS and customers. AWS secures the underlying cloud infrastructure, while customers are responsible for securing their data, applications, and configurations.	K2
17.	**What are inherited controls?** Inherited controls are security controls that are fully managed by AWS and automatically inherited by customers. Examples include physical data center security, hardware maintenance, and environmental protections.	K1
18.	**What are shared controls?** Shared controls are security responsibilities that are divided between AWS and customers. Examples include patch management, configuration management, and monitoring activities where both parties contribute to security.	K2
19.	**What are customer-specific controls?** Customer-specific controls are security measures that are completely managed by customers. These controls include data classification, IAM policies, encryption settings, application security, and compliance management.	K2
20.	**What is AWS Identity and Access Management (IAM)?** AWS IAM is a web service that securely controls access to AWS resources. It enables organizations to manage authentication, authorization, and permissions for users, applications, and AWS services.	K1
21.	**What is authentication?** Authentication is the process of verifying the identity of a user, application, or service before granting access. Common authentication methods include passwords, access keys, MFA, and federated identities.	K1

22.	**What is authorization?** Authorization determines what actions an authenticated user or application can perform on AWS resources. It is implemented through IAM policies that define permissions and access restrictions.	K1
23.	**What is an IAM User?** An IAM User represents a person or application that interacts with AWS resources. IAM users possess permanent credentials and can access AWS services through the Management Console, APIs, or AWS CLI.	K1
24.	**What is an IAM Group?** An IAM Group is a collection of IAM users that share common permissions. Assigning permissions to groups simplifies administration because all users within the group automatically inherit those permissions.	K1
25.	**What is an IAM Role?** An IAM Role is an AWS identity that provides temporary security credentials. Roles can be assumed by users, applications, or AWS services to securely access AWS resources without using long-term credentials.	K1
26.	**What is an IAM Policy?** An IAM Policy is a JSON document that defines permissions in AWS. It specifies which actions are allowed or denied, the resources affected, and the conditions under which access is granted.	K1
27.	**Who is called a principal in AWS IAM?** A principal is an authenticated entity that makes requests to AWS resources. Examples include IAM users, IAM roles, federated users, root users, and AWS services.	K1
28.	**What is Multi-Factor Authentication (MFA)?** MFA is a security mechanism that requires users to provide an additional verification factor besides a password. It significantly enhances account security and reduces the risk of unauthorized access.	K1
29.	**What are temporary credentials in AWS?** Temporary credentials are short-lived security credentials issued by AWS Security	K1

R.M.K GROUP OF INSTITUTIONS

	Token Service (STS). They automatically expire after a specified period and are commonly used with IAM roles and federated access.	
30.	**What is AWS Organizations?** AWS Organizations is a service that enables centralized management of multiple AWS accounts. It supports consolidated billing, governance, policy enforcement, and hierarchical account management through Organizational Units (OUs).	K1

12. PART B QUESTIONS

1.	Explain cloud security in detail. Discuss its importance, benefits, and the seven areas of cloud security.	K3
2.	Describe the CIA Triad of Information Security. Explain how Confidentiality, Integrity, and Availability contribute to cloud security.	K3
3.	Discuss the objectives of AWS Cloud Security with suitable examples. Explain controllability, auditability, visibility, and agility & automation.	K3
4.	Explain the AWS Security Design Principles in detail and discuss their significance in building secure cloud environments.	K3
5.	Describe the AWS Shared Responsibility Model. Differentiate between AWS responsibilities and customer responsibilities with examples.	K3
6.	Explain the various types of security controls in AWS. Discuss inherited controls, shared controls, and customer-specific controls with examples.	K3
7.	Explain AWS Identity and Access Management (IAM). Discuss IAM users, groups, roles, policies, and IAM best practices.	K3
8.	Describe the authentication mechanisms provided by AWS IAM. Explain IAM roles, security credentials, temporary credentials, and Multi-Factor Authentication (MFA).	K3
9.	Explain the authorization process in AWS IAM. Discuss the principle of least privilege, policy types, policy evaluation logic, and permissions boundaries.	K4
10.	Explain AWS Organizations and Service Control Policies (SCPs). Discuss different AWS Organization policy types and their role in governance and security management.	K4

13. ONLINE CERTIFICATIONS

1. **AWS Certified Cloud Practitioner**

   AWS Certified Cloud Practitioner Certification | AWS Certification | AWS (amazon.com)

2. **AWS Certified Solutions Architect – Associate**

   https://aws.amazon.com/certification/certified-solutions-architect-associate/

3. **AWS Certified Security – Specialty**

   https://aws.amazon.com/certification/certified-security-specialty/

R.M.K GROUP OF INSTITUTIONS

14. REAL TIME APPLICATIONS

AI-Based Cloud Security Monitoring and Threat Detection

Organizations today use cloud services to store data, run applications, and manage business operations. As the number of cloud resources increases, the amount of security data generated every day also grows. Security teams must monitor these activities to identify threats such as unauthorized access, phishing attacks, malware, and data breaches.

Traditional security monitoring requires analysts to manually examine logs and write complex queries, which can be time-consuming and difficult for beginners. To solve this problem, Sumo Logic developed an AI-powered security assistant using Amazon Bedrock and Amazon Nova models. The solution helps security teams analyze security events quickly and efficiently using natural language.

Application Overview:

The AI-powered security assistant allows users to ask security-related questions in simple English instead of writing technical queries.

Examples include:

- What happened in the last 24 hours?
- Were there any suspicious login attempts today?
- Did any security threats occur overnight?

The AI assistant analyzes large amounts of security data and provides clear answers and recommendations. This helps organizations identify threats faster and improve security operations.

How the System Works

1. Security logs are collected from cloud services, applications, and network devices.
2. The AI system analyzes the collected data and looks for unusual activities.
3. Users ask questions using natural language.
4. The AI identifies potential threats and security incidents.
5. The system provides a summary of the incident and suggests actions to resolve it.

For example, instead of showing many separate alerts, the system may provide a summary such as:

"A user clicked a suspicious email link and later logged in from an unusual location. A phishing attack is suspected. Immediate action is recommended."

R.M.K GROUP OF INSTITUTIONS

Threats Detected

The system can identify various security threats, including:

- Unauthorized login attempts
- Phishing attacks
- Malware activities
- Insider threats
- Data leakage incidents
- Privilege escalation attacks

By continuously monitoring security logs, the AI can detect threats at an early stage and help prevent serious damage.

Benefits of the Solution

Faster Threat Detection

Reduced Manual Effort

Easy to Use

Better Decision Making

Improved Productivity

Cost Savings

AWS Services Used

- **Amazon Bedrock** – Provides generative AI capabilities.
- **Amazon Nova** – Analyzes and understands security data.
- **AWS CloudTrail** – Records user activities and API actions.
- **Amazon CloudWatch** – Monitors logs and system performance.
- **AWS Security Hub** – Collects and manages security findings.

Conclusion

AI-powered security monitoring helps organizations improve cloud security by detecting threats quickly and providing intelligent recommendations. The Sumo Logic solution demonstrates how Amazon Nova and Amazon Bedrock can simplify security analysis, reduce response time, and improve overall security management. As cloud environments continue to grow, AI-based security solutions will become increasingly important for protecting organizational data and resources.

Accelerating security analytics using Amazon Nova with Sumo Logic | Case Study | AWS

R.M.K GROUP OF INSTITUTIONS

15. SELF-LEARNING / ENRICHMENT TOPICS

1. Recent Cloud Security Breaches and Lessons Learned

   Study real-world cloud security incidents and analyze their causes and preventive measures.

2. Zero Trust Security Model

   Explore the concept of "Never Trust, Always Verify" and its role in modern cloud security.

3. Multi-Factor Authentication (MFA) Technologies

   Compare hardware tokens, authenticator apps, biometric authentication, and security keys.

4. Comparison of Cloud Security Models

   Compare security approaches in AWS, Microsoft Azure, and Google Cloud Platform (GCP).

5. Cloud Compliance Standards

   Overview of standards such as ISO 27001, GDPR, HIPAA, and PCI DSS in cloud environments.

R.M.K GROUP OF INSTITUTIONS

16. ASSESSMENT SCHEDULE

Tentative schedule for the Assessment During 2025-2026 Odd semester

S.NO	Name of the Assessment	Start Date	End Date	Portion
1	IAT 1			UNIT 1 & 2
2	IAT 2			UNIT 3 & 4
3	REVISION			UNIT 5, 1 & 2
4	MODEL			ALL 5 UNITS

R.M.K GROUP OF INSTITUTIONS

17. PRESCRIBED TEXT BOOKS AND REFERENCES

TEXT BOOKS:

1. Tim Mather, Subra Kumaraswamy, Shahed Latif, "Cloud Security and Privacy, An Enterprise Perspective on Risks and Compliance", Oreilly Media 2009.
2. Vic (J.R.) Winkler, "Securing the Cloud, Cloud Computer Security Techniques and Tactics", Syngress, April 2011.

REFERENCES:

1. Rajkumar Buyya, James Broberg, Andrzej, "Cloud Computing: Principles and Paradigms", Wiley India Publications 2011.
2. Arshdeep Bahga and Vijay Madisetti, "Cloud Computing –A Hands on Approach", Universities Press (India) Pvt Ltd. 2014.

R.M.K GROUP OF INSTITUTIONS

18. MINI PROJECT

Mini-Project 1: Cloud Security Awareness Brochure (CO1, K3)

Objective:

Create an awareness brochure on cloud security best practices for new cloud users.

Tasks:

1. Explain common cloud security threats.
2. Describe the CIA Triad.
3. Include security best practices for cloud users.
4. Design the brochure using PowerPoint or Canva.
5. Present the brochure to the class.

Mini-Project 2: Shared Responsibility Model Comparison Chart (CO1, K4)

Objective:

Develop a visual comparison of security responsibilities across cloud service models.

Tasks:

1. Study IaaS, PaaS, and SaaS.
2. Identify provider and customer responsibilities.
3. Create a comparison chart or infographic.
4. Include at least three real-world cloud service examples.
5. Present the findings.

Mini-Project 3: IAM Design for a College Management System (CO1, K4)

Objective:

Design an IAM structure for a cloud-based college management system.

Tasks:

1. Identify different user roles such as Student, Faculty, HOD, and Administrator.
2. Define access permissions for each role.
3. Create a role-permission matrix.

R.M.K GROUP OF INSTITUTIONS

4. Apply the principle of least privilege.
5. Prepare a report with diagrams.

Mini-Project 4: Authentication Methods Evaluation (CO1, K4)

Objective:

Compare authentication methods used in cloud environments.

Tasks:

1. Study passwords, MFA, biometrics, and SSO.
2. Compare them based on security, usability, and cost.
3. Create a comparison table.
4. Recommend suitable methods for different organizations.
5. Present conclusions with supporting reasons.

Mini-Project 5: Secure Cloud Startup Plan (CO1, K5)

Objective:

Develop a basic security plan for a startup migrating to the cloud.

Tasks:

1. Identify organizational roles.
2. Define authentication and access control requirements.
3. Recommend security design principles.
4. Create a simple cloud governance policy.
5. Prepare a security planning document.

R.M.K GROUP OF INSTITUTIONS

Thank you

Disclaimer:

This document is confidential and intended solely for the educational purpose of RMK Group of Educational Institutions. If you have received this document through email in error, please notify the system manager. This document contains proprietary information and is intended only to the respective group / learning community as intended. If you are not the addressee you should not disseminate, distribute or copy through e-mail. Please notify the sender immediately by e-mail if you have received this document by mistake and delete this document from your system. If you are not the intended recipient you are notified that disclosing, copying, distributing or taking any action in reliance on the contents of this information is strictly prohibited.

R.M.K GROUP OF INSTITUTIONS